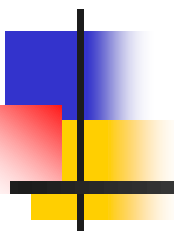


C12 資訊安全風險評估與管理



12-1 風險評估與管理基本概念

12-2 風險評估過程

12-3 風險控制過程

12-4 風險評估與管理方法



12-1 風險評估與管理基本概念

- 什麼時候才能阻止網路駭客入侵？
- 答案是：**永遠不會**。
- 網路世界也是一樣的道理，**我們最多能做的就是儘可能管理風險**，將風險降到最低，一如在實體世界的做法。

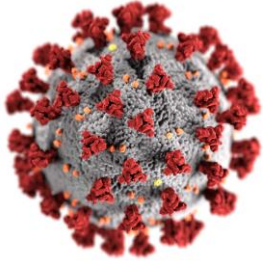
12-1-1 與風險評估有關的概念

- 1. **威脅 (Threat)**，是指可能對資產或組織造成損害事故的潛在原因。
- 2. **薄弱點 (Vulnerability)**，是指資產或資產組中能被威脅利用的弱點。(ex, **password**)
- 3. **風險 (Risk)** 是特定威脅事件發生的可能性與後果的結合。
- 4. **風險評估 (Risk Assessment)**，對資訊和資訊處理設施的威脅、影響和薄弱點及三者發生可能性的評估。



Covin-19

威脅 (**Threat**)



薄弱點 (**Vulnerability**)



風險 (**Risk**)



What is threat?

- **Natural threats**, such as floods, hurricanes, or tornadoes
- **Unintentional threats**, like an employee mistakenly accessing the wrong information → **examples like ...?**
- **Intentional threats**, such as spyware, malware, adware companies, or the actions of a disgruntled employee



What is a vulnerability?

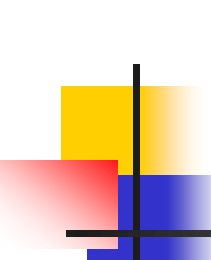
- a known **weakness** of an asset (resource) that can be exploited by one or more attackers
- For example, when a team member resigns and you forget to disable their access to external accounts, change logins, or remove their names from company credit cards

What is this?



What is a vulnerability?





What is a vulnerability?

- some questions for determining your security vulnerabilities:
 1. Is your data backed up and stored in a secure off-site location?
 2. Is your data stored in the cloud? If yes, how exactly is it being protected from cloud vulnerabilities?
 3. What kind of network security do you have to determine who can access, modify, or delete information from within your organization?
 4. What kind of antivirus protection is in use? Are the licenses current? Is it running as often as needed?
 5. Do you have a data recovery plan in the event of a vulnerability being exploited?
 6. Ransomware
- Understanding yr vulnerabilities is the 1st step to managing your risk.

What is risk?

- Risk is defined as **the potential for loss or damage when a threat exploits a vulnerability**
 - Financial losses
 - Loss of privacy
 - Damage to your reputation
 - Legal implications
 - Even loss of life
- ***Risk = Threat x Vulnerability***
- ***Cyber risk = Threat x Vulnerability x Information Value***
(<https://www.upguard.com/blog/cyber-security-risk-assessment>)
- Reduce your potential for risk by creating and implementing a **risk management** plan



Example



- **Threat:** hurricane, earthquake
- **Vulnerability:** not having a data recovery plan in place in the event that your physical assets are damaged as a result of the hurricane
- **Risk:** the loss of information or a disruption in business



Example: <https://www.compuquip.com/blog/cybersecurity-threats-vulnerabilities>

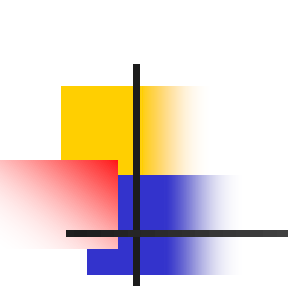
- **Threat:** Cyber-attacks like Computer virus/ Rogue security software/ Trojan horse/ Adware and spyware/ Computer worm/ DOS and DDOS attack/ Phishing/Rootkit.
- **Vulnerability:** Unpatched Security Vulnerabilities; Hidden Backdoor Programs; Superuser or Admin Account Privileges; Automated Running of Scripts without Malware/Virus Checks; Unknown Security Bugs in Software or Programming Interfaces; **IoT Devices; Phishing (Social Engineering) Attacks; Employees**
- **Risk:** the loss of information or a disruption in business/賠錢/信譽/生命...



risk management strategy:

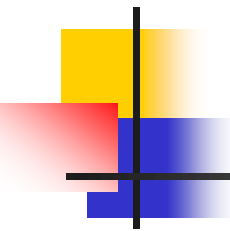
- **Assess risk and determine needs** : assessment must be done on a **regular, recurring** basis.
- **Include a total stakeholder (利益相關者) perspective.**
- **Designate a central group of employees** who are responsible for risk management and determine the appropriate funding level for this activity.
- **Implement appropriate policies and related controls** and ensure that the appropriate end users are informed of any and all changes.
- **Monitor and evaluate policy and control effectiveness**

Q: 以學生學習履歷事件 那些是**a total stakeholder (利益相關者)**

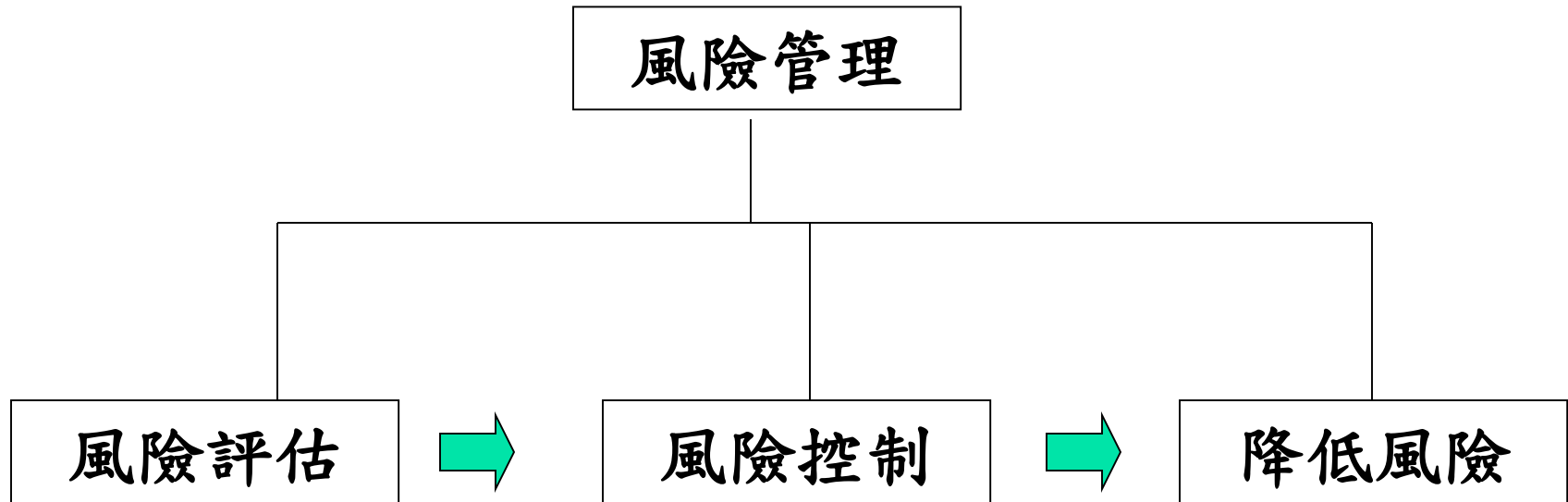


12-1-2 與風險管理有關的概念

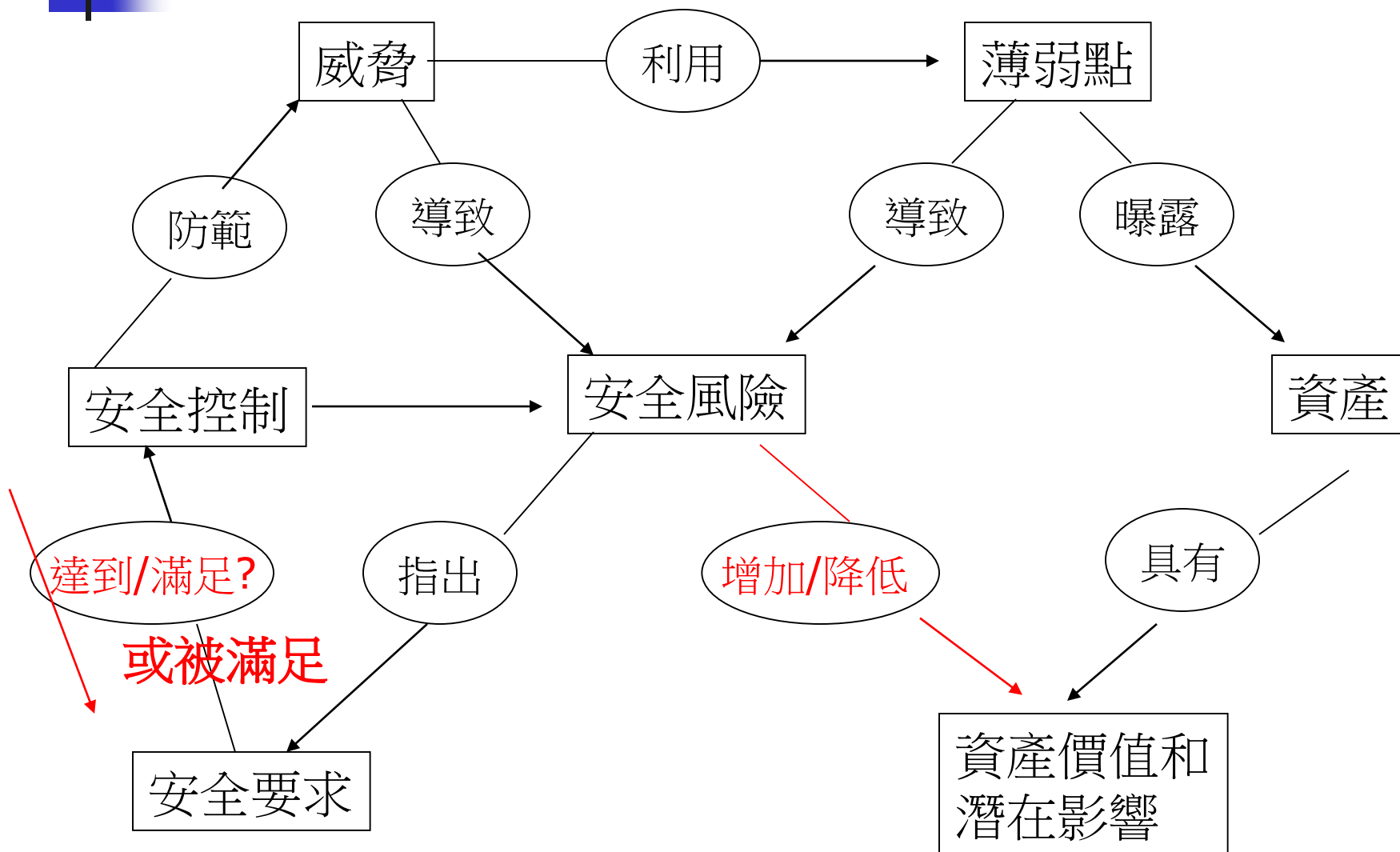
- 1.風險管理（Risk Management），以可接受的**成本費用**以識別、**控制、降低或消除**可能影響資訊系統的安全風險的過程。
- 2.安全控制（Security Control），降低安全風險的慣例、程序或機制。
- 3.剩餘風險（Residual Risk），實施安全控制後，剩下的安全風險。
- 4.適用性聲明（Applicability Statement），適用於組織需要的目標和控制的評述。
 - 包含組織所選擇的控制目標與控制方式的文件



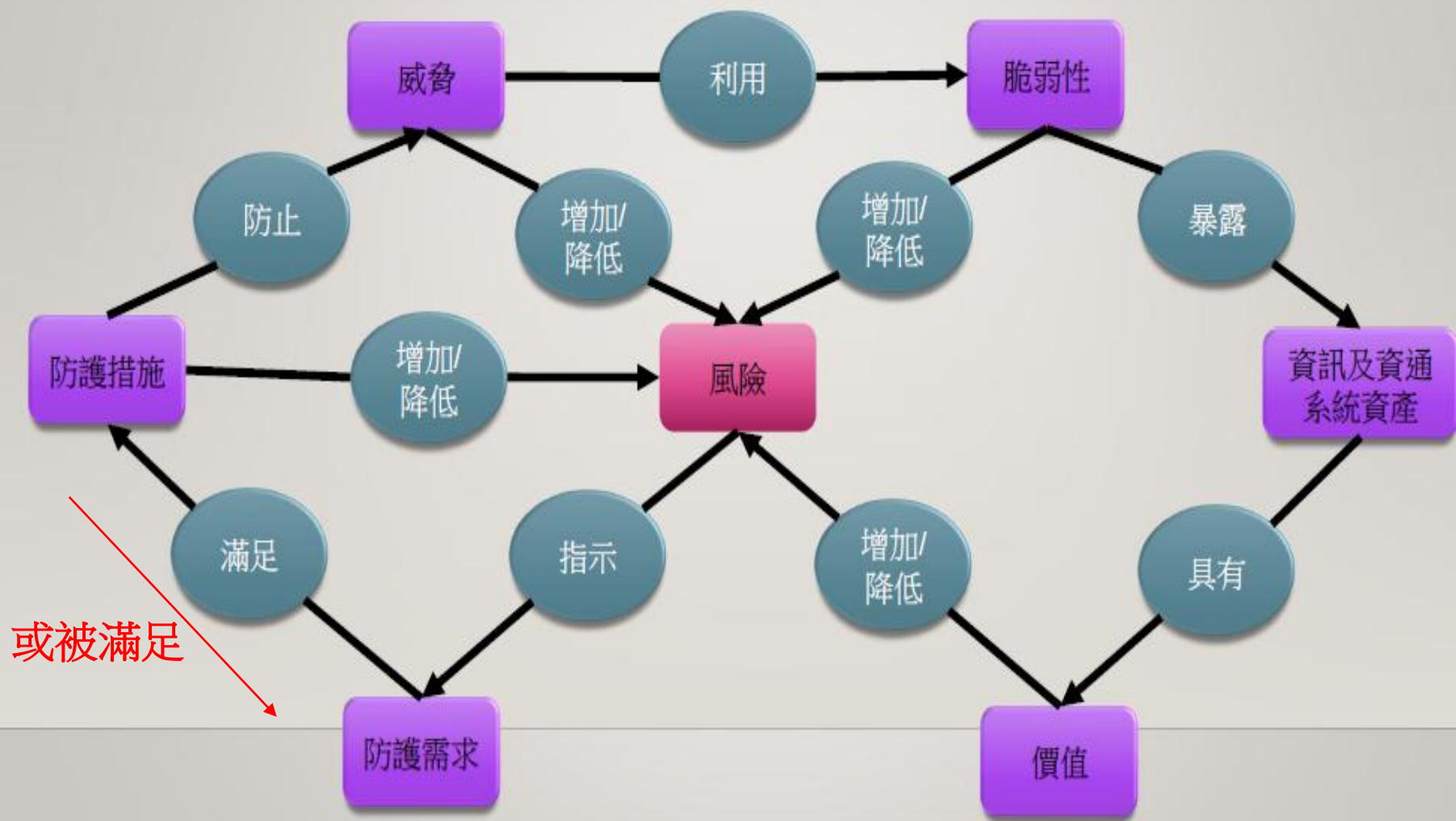
風險管理過程結構



風險評估與管理術語關係圖 X



風險管理關係圖 X



♠ ♠ ♠ This One is Good 管理術語關係圖

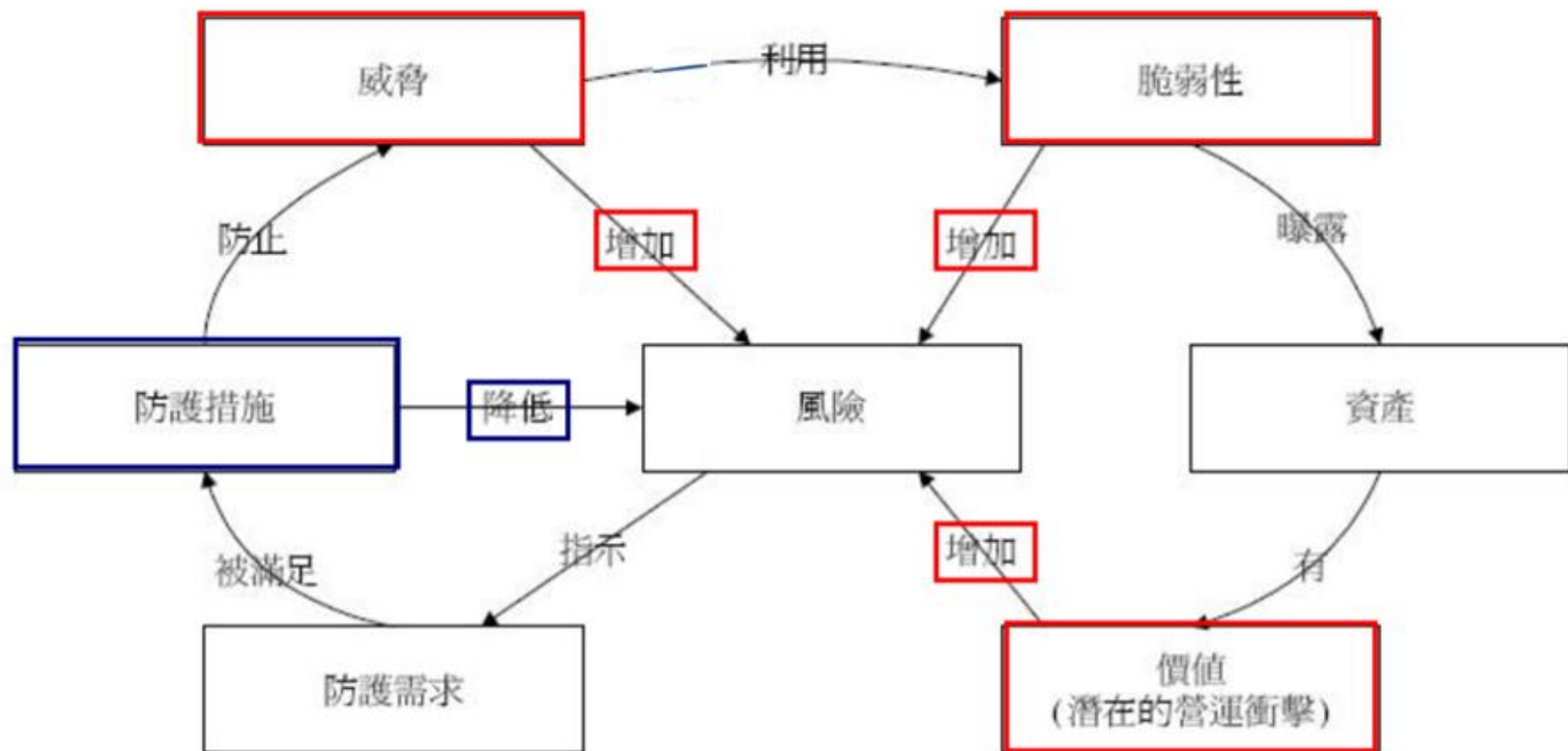


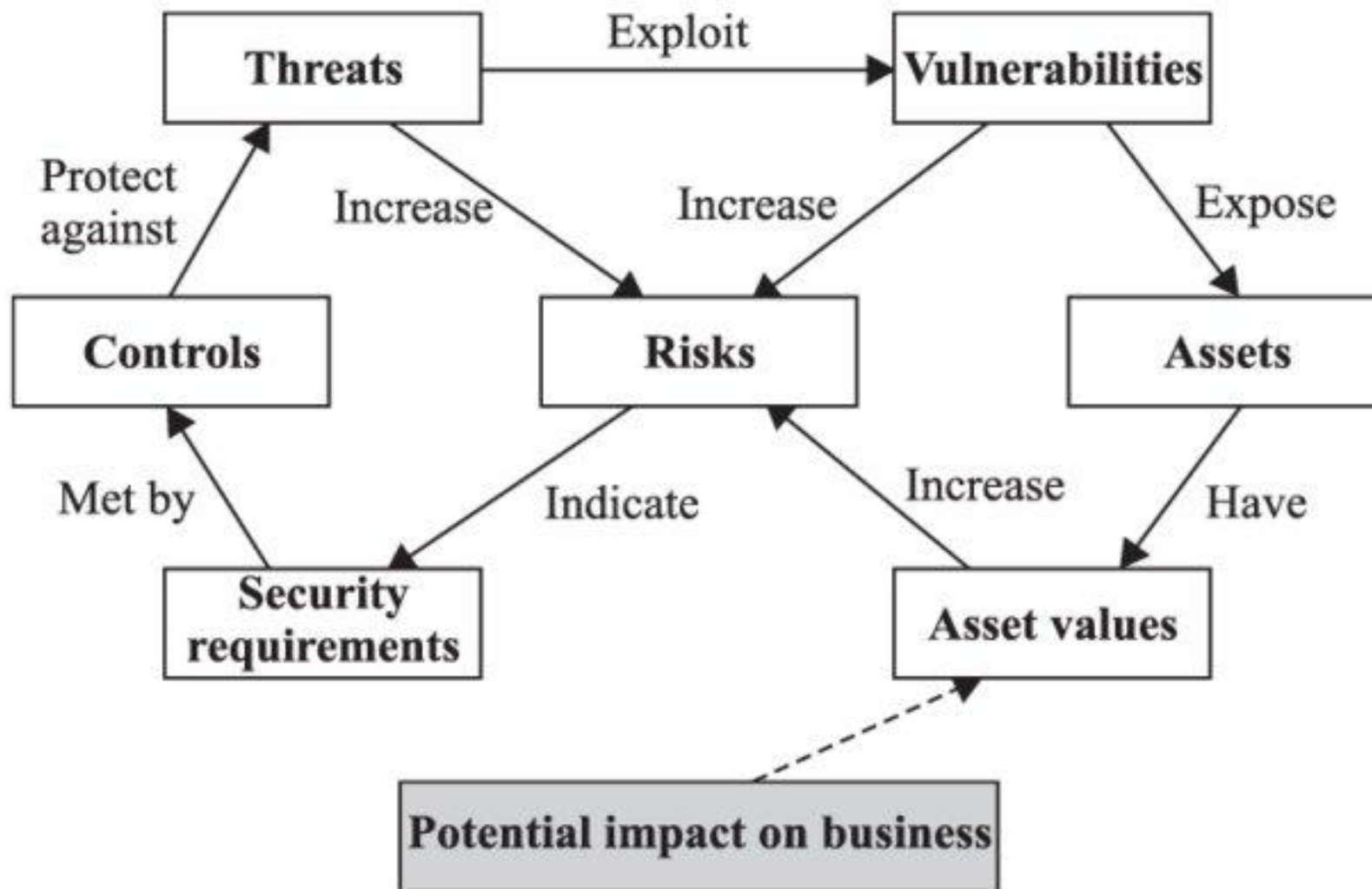
Diagram of interrelationships in risk management

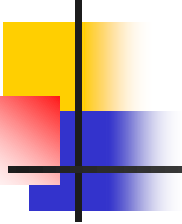
https://www.researchgate.net/publication/228461586_Implementation_of_information_security_management_system_in_the_small_healthcare_organization/figures?lo=1



This One is Good

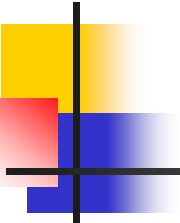
管理術語關係圖





12-1-3 術語概念之間的關係

- 資產具有價值，並會受到威脅的潛在影響。
- 薄弱點將資產暴露給威脅，威脅利用薄弱點對資產造成影響。
- 威脅與薄弱點的增加導致安全風險的增加。
- 安全風險的存在對組織的資訊安全提出要求。
- 安全控制應滿足安全要求。
- 組織通過實施安全控制防範威脅，以降低安全風險。



12-2 風險評估過程

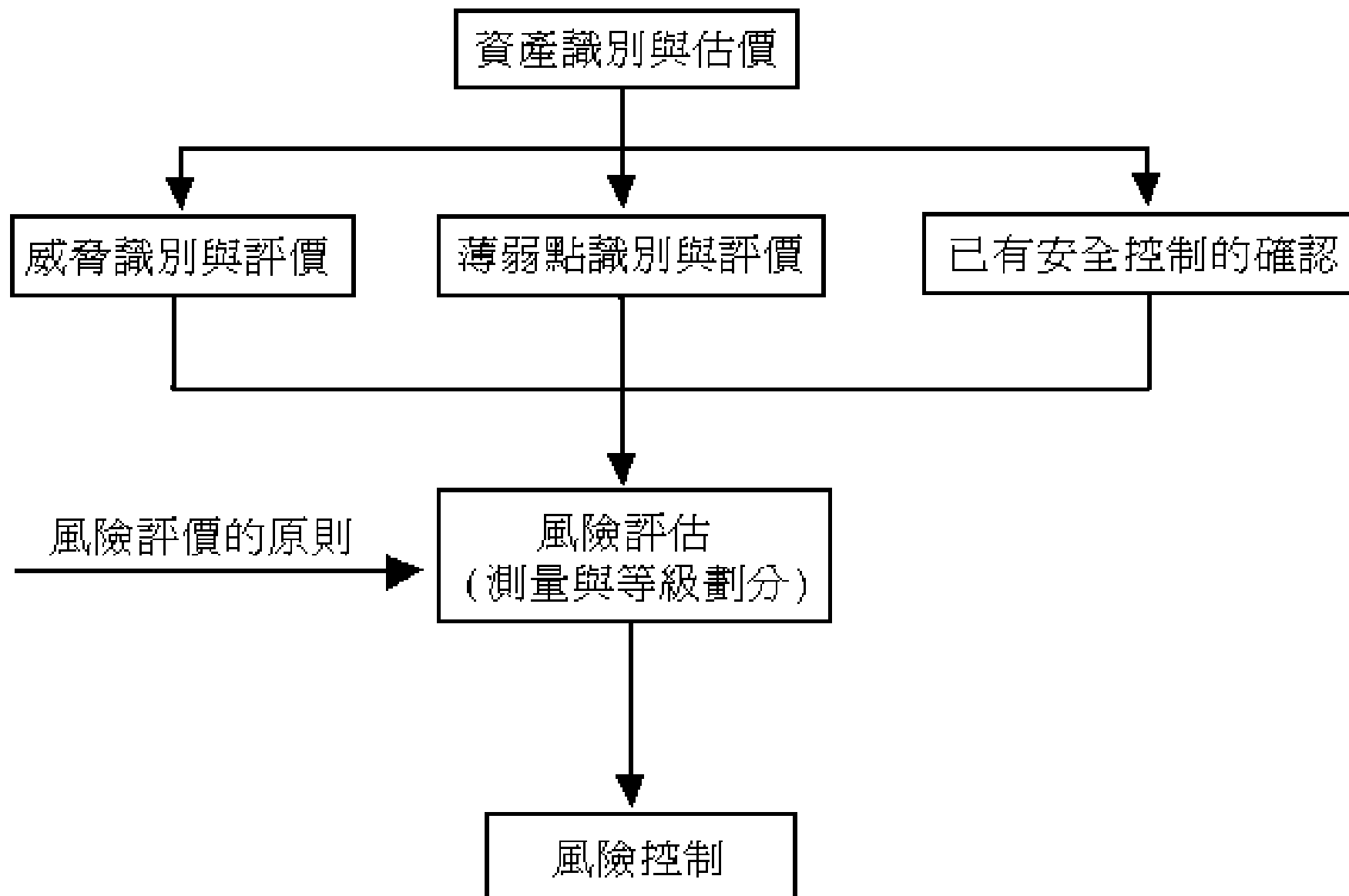
- 風險評估（也稱風險分析）是風險管理的基礎，是組織確認資訊安全要求的途徑之一，屬於組織資訊安全管理體系策劃的過程。
- 透過風險評估識別組織所面臨的安全風險並確認風險控制的優先等級，進而對其實施有效控制，將風險控制在組織可以接受的範圍之內。



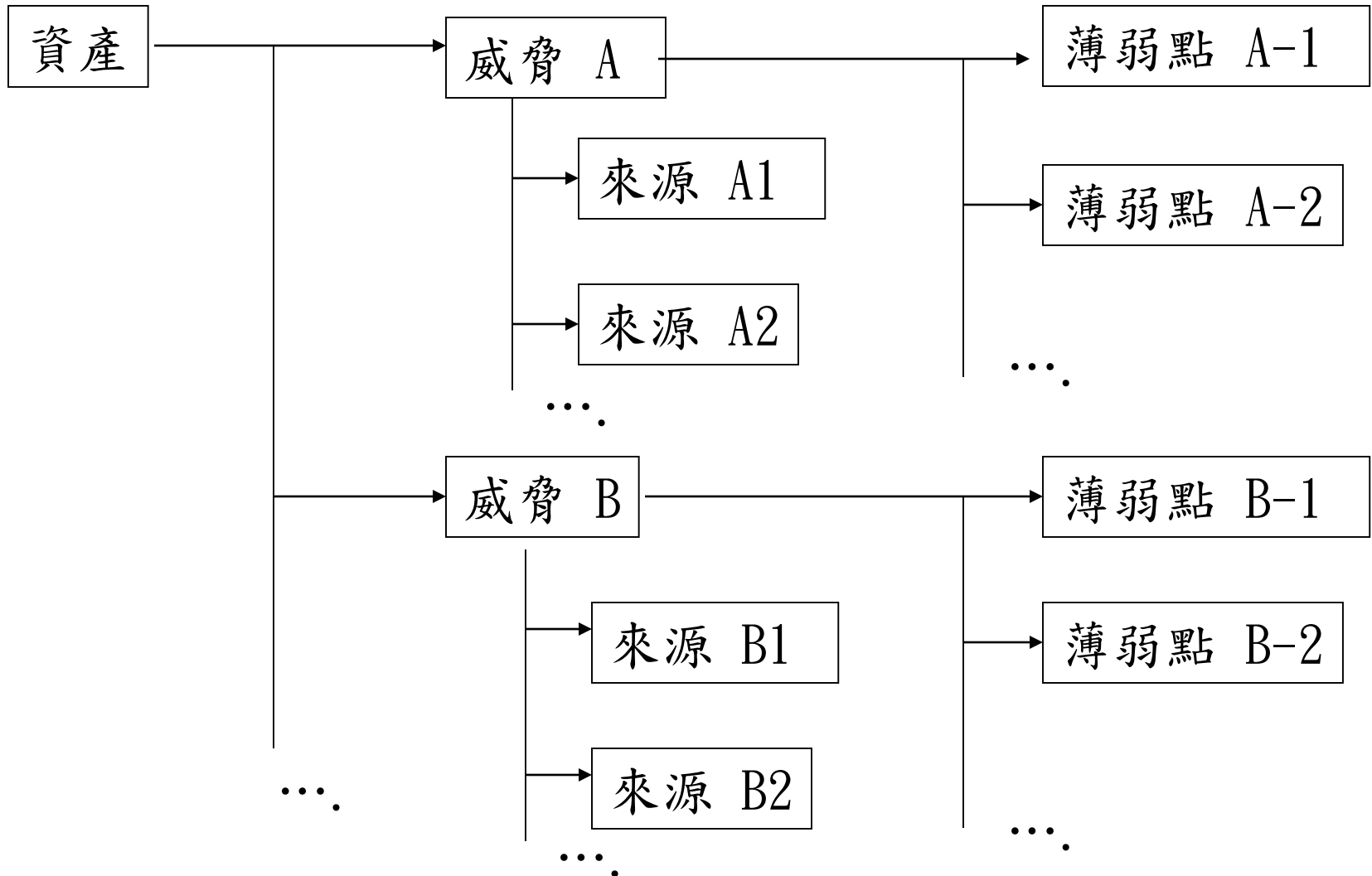
12-2-1 風險評估的基本步驟

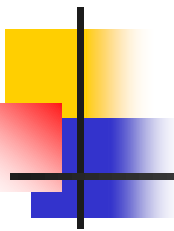
- 1 · 風險評估應考慮的因素
 - 資產價值, 威脅及可能性, 薄弱點, 已有之安全措施
- 2 · 風險評估的基本步驟 (下一頁)
- 3 · 進行風險評估時, 應考慮的對應關係 (下二頁)

風險評估過程圖



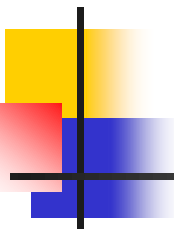
資產，威脅與薄弱點關係圖





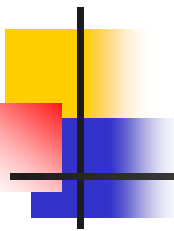
12-2-2 資產識別與估價

- 為了明確被保護的資訊資產，組織應列出與資訊安全有關的**資產清單**，對每一項資產進行確認和適當的評估。
- 為了防止資產被忽視或遺忘，在識別資產之前應**確定風險評估範圍**。
- 列出對組織或組織的特定部門的業務過程有價值的任何事物，以便根據組織的商務流程來識別資訊資產。



12-2-3 威脅識別與評價

- 對組織需要保護的**每一項關鍵資訊資產**進行**威脅識別**。
- 在威脅識別過程中，應根據資產所處的環境條件和資產以前遭受威脅損害的情況來判斷，**一項資產可能面臨著多個威脅，同樣一個威脅可能對不同的資產造成影響。**
- **威脅識別應確認威脅由誰或什麼事物引發以及威脅影響的資產。**



影響威脅發生的可能性因素

- 1. 資產吸引力
- 2. 資產轉化為報酬的容易度（如：電玩代幣）
- 3. 威脅的技術含量
- 4. 薄弱點被利用的難易程度

Q: 學生資料是否容易轉化為報酬?

Q: 對業主的名聲/業務 造成困擾程度?

Q: 學生有哪些資產容易被威脅利用轉換為報酬

12-2-4 薄弱點評價與已有控制措施的確認

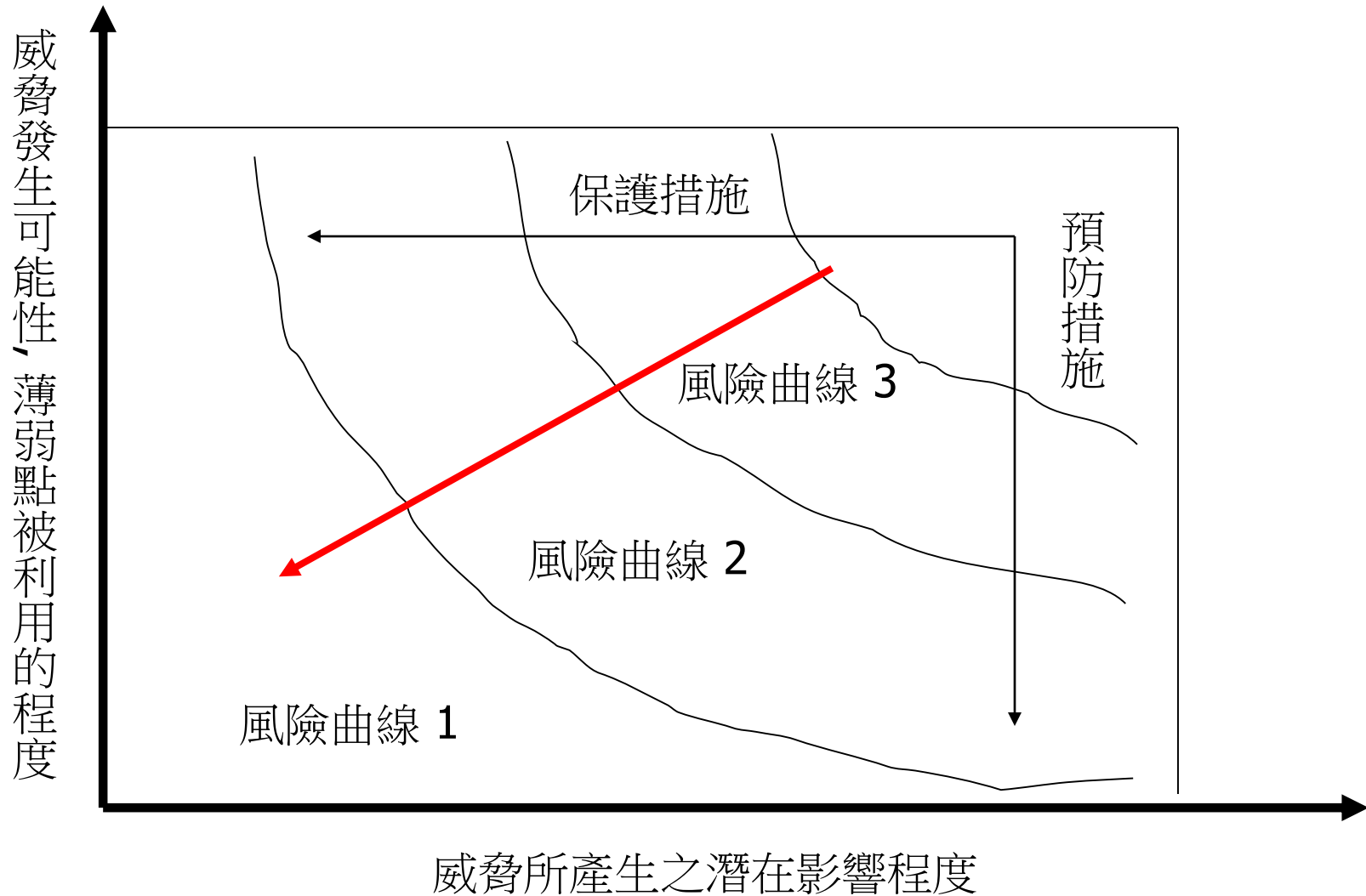
■ 1・薄弱點的識別與評價

組織應針對每一項需要保護的資訊資產，找出每一種威脅所能利用的薄弱點，並對薄弱點的嚴重性進行評價。

■ 2・對已有的安全控制進行確認

組織應將已採取的控制措施進行識別並對控制措施的有效性進行確認。

控制措施與風險程度

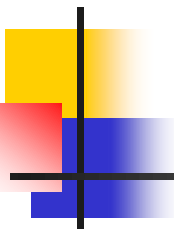




12-2-5 風險評估

- 資產識別與估價 → 威脅與薄弱點的識別與評價 → 已有控制措施的確認後

- → 應利用適當的風險測量方法或工具確定風險的大小與風險等級，即對組織資訊安全管理範圍內的每一資訊資產因遭受洩露、修改、不可用和破壞所帶來的任何影響做出一個風險測量的列表，以便識別與選擇適當和正確的安全控制方式。



風險測量方法 (1)

- 風險是資產所受到的威脅、存在的薄弱點及威脅利用薄弱點所造成的潛在影響三方面共同作用的結果。
- 風險是威脅發生的可能性、薄弱點被威脅利用的可能性和威脅的潛在影響的函數，記為：

- $R=R(P_T, P_V, I)$

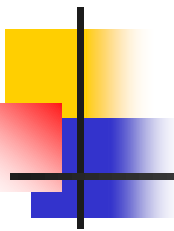
- R：資產受到某一威脅的風險

- P_T ：威脅發生的可能性

- P_V ：薄弱點被利用的可能性

- I：威脅的潛在影響 ($I=V * C_L$)

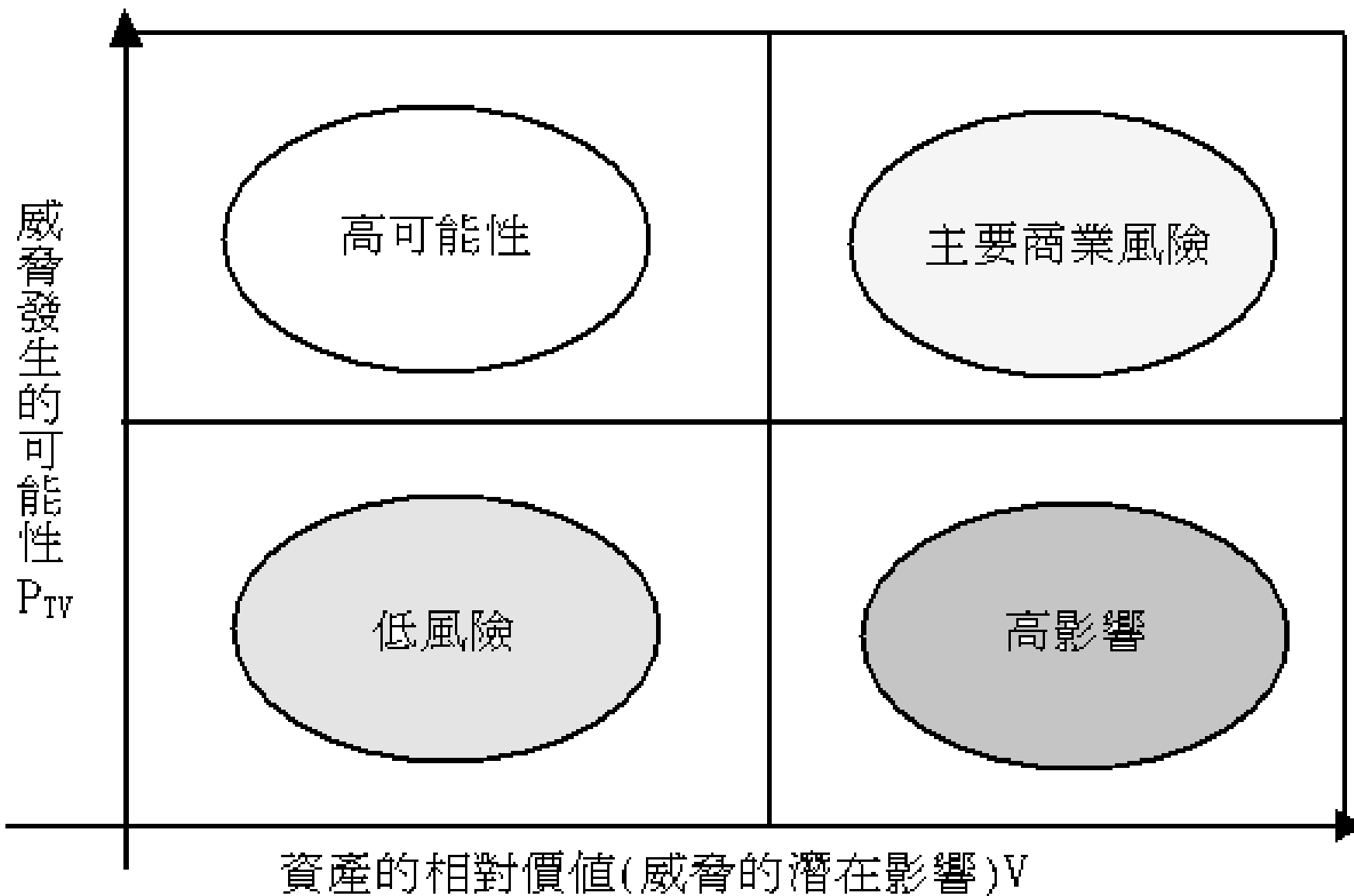
- 威脅的潛在影響 $I=$ 資產相對價值 $V * 價值損失程度 C_L$
 $0 \leq C_L \leq 1$



風險測量方法 (2)

- $P_{TV} = P_T \times P_V$
 - P_{TV} —考慮資產薄弱點因素的威脅發生的可能性
 - P_T —未考慮資產薄弱點因素的威脅發生可能性
 - P_V —資產的薄弱點被威脅利用的可能性
- 威脅潛在影響 $I = \text{資產相對價值 } V * \text{價值損失程度 } C_L$
- $R = R(P_T, P_V, I)$ or $R = R(P_T, P_V, V)$ ← 為何可以這樣寫

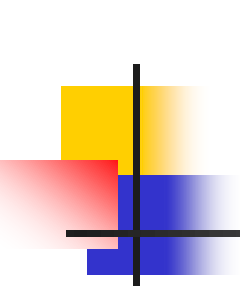
風險區域示意圖



風險價值矩陣表

這個三角代表？

	威脅發生可能性 PT	低 0			中 1			高 2		
	薄弱點被利用的可能性 PV	低 0	中 1	高 2	低 0	中 1	高 2	低 0	中 1	高 2
資產相對價值	0	0	1	2	1	2	3	2	3	4
	1	1	2	3	2	3	4	3	4	5
	2	2	3	4	3	4	5	4	5	6
	3	3	4	5	4	5	6	5	6	7
	4	4	5	6	5	6	7	6	7	8



風險評估—風險管理工具的選擇

- 一旦風險評估被完成，評估的結果（資產和它們的價值，威脅—薄弱點和風險等級，以及被確認的控制）應該被保存和檔案化，例如，儲存在資料庫裡。
- 企業組織或政府單位可以利用軟體支援工具進行風險評估活動，這可以使再評估活動更容易。

12-3 風險控制過程

風險評估過程



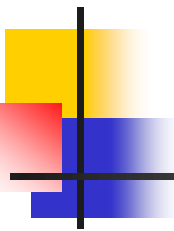
安全控制的識別和選擇



實施控制降低風險

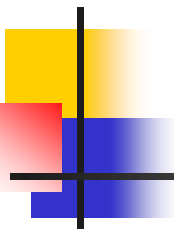


風險接受



12-3-1 安全控制的識別和選擇

- 為了降低或消除資訊安全管理體系範圍所涉及到的被評估的風險，組織應識別和**選擇適宜且合理的安全控制**。
- 透過實施安全控制**使風險降低到**組織可接受的程度。
- 安全控制的選擇應以風險評估的結果作為依據，判斷與威脅相關聯的薄弱點，決定什麼地方需要保護，以及應該採取何種形式的控制。



12-3-2 風險控制

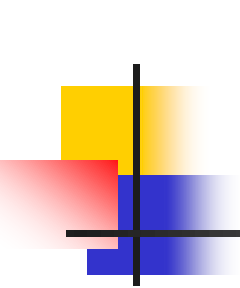
- 根據**控制費用與風險平衡的原則**，組織對所選擇的安全控制應嚴格實施並保持，即透過以下途徑達到風險降低的目的：

- (1) **避免風險**：如隔離
- (2) **轉移風險**；如保險
- (3) **減少威脅**；如惡意軟體控制程式
- (4) **減少薄弱點**：如人員教育訓練
- (5) **減少威脅可能的影響程度**；商務持續性計畫, 備援及恢復
- (6) **探測有害事故**；如入侵檢測工具



12-3-3 風險接受

- 組織在實施選擇的控制後，總是有殘留的風險，稱之為**殘留風險或殘餘風險**。
- **殘餘風險**也可能是某些資產未被有意保護所致，例如，假設的低風險或者被提及的控制需要高費用而未採取應有的控制。
- 為確保組織的資訊安全，殘餘風險應在可接受的範圍內。



動態風險評估的時機

- (1) 當組織新增資訊資產時
- (2) 當系統發生重大變更時
- (3) 發生嚴重資訊安全事故時
- (4) 組織認為有必要時

Q: 暨大事件對應到上方 …



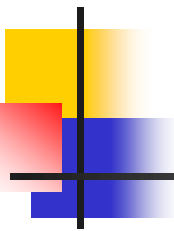
12-4 風險評估與管理方法

- 為了達到自我安全的要求，**定期**的反省檢討安全措施是必要的步驟。
- 為了確認定期檢討的內容，也因此**需要一套系統的分析方法**，才能發現問題的所在。這樣一套有系統的方法即為風險評估方法。
- 在風險評估和風險管理方法被應用的過程中，評估時間、強度，以及具體開展的深度應與組織的環境和安全要求相稱。



12-4-1 基本的風險評估

- 基本的風險評估是一種直接和簡單的方法，包括對組織所考慮的資訊和財產安全要求的一個系統的評估，識別那些令人滿意的控制目標和對滿足這些目標的一系列控制進行選擇。
- 這種方法適用於商業運作不是非常複雜，並且組織對資訊處理和網路的依賴程度不高的組織。



12-4-2 詳細的風險評估

- 這個方法包括對資產的詳細識別和估價，以及那些對資產形成威脅和相關薄弱點水平的評估，上述結果被用於評估風險並隨後被用於安全控制的識別和選擇。
- 詳細的風險評估可能是非常耗費財力的過程，因此需要非常仔細制定被評估的資訊系統範圍內的商務環境、運作、資訊和資產的界限。



12-4-3 聯合評估方法

- 這種方法首先使用基本的風險評估方法，識別資訊安全管理範圍內具有潛在的高風險或對商業運作來說極為關鍵的資產
- 然後根據基本的風險評估的結果，將資訊安全管理範圍內的資產分成兩類，一類需要應用一個詳細的風險評估方法以達到適當保護，另一類透過基本評估方法選擇的控制。

12-4-4 風險評估和管理方法的選擇應考慮的因素

- 組織可採取不同的風險評估和風險管理方法，一個方法是否適合於特定組織有很多影響因素，包括：
 - (1) 商務環境
 - (2) 商務性質和重要性
 - (3) 對支援組織商務的資訊系統的技術性和非技術性依賴
 - (4) 商務及其支援系統、應用軟體和 服務的複雜性
 - (5) 商業夥伴和外部業務以及合約關係的數量

流程範例（以資訊資產為標的 ISO 27001:2005版的流程）

每一項資訊資產，都要進行以下流程評估

1. 資訊資產識別
2. 資訊資產類別
3. 鑑別資訊資產價值
鑑別重不重要，用機密性 完整性 可用性來分級

1. 資訊資產評估

資產價值 = 機密性 + 完整性 + 可用性

2. 威脅與脆弱性識別

威脅 脆弱性

3. 現有控制措施識別

4. 評鑑事故可能性 威脅等級 脆弱性等級

5. 估計風險等級

資訊資產價值 = 機密性鑑價 + 完整性鑑價 + 可用性鑑價

資訊資產風險值 = 資訊資產價值 * 威脅等級 * 脆弱性等級

6. 風險評估

訂定風險等級 可接受風險等級

○ 高 55~81

○ 中 29~54

○ 普 3~28

7. 風險評鑑複合

8. 風險處理

9. 風險追蹤



個資與帳密頻遭大量竊取

- 學習歷程檔案遺失 蘇貞昌指派資安處全面體檢

<https://tw.news.yahoo.com/news/%E5%AD%B8%E7%BF%92%E6%AD%B7%E7%A8%8B%E6%AA%94%E6%A1%88%E9%81%BA%E5%A4%B1-%E8%98%87%E8%B2%9E%E6%98%8C%E6%8C%87%E6%B4%BE%E8%B3%87%E5%AE%89%E8%99%95%E5%85%A8%E9%9D%A2%E9%AB%94%E6%AA%A2-060356559.html>

- 學習歷程檔案資料庫發生重大疏失
- 檔案遺失
- 教育部&學校 信譽受損
- 商務受損
- 學校師生及家長的困擾及負擔
- 線上和實地並行的方式行訪視和檢查
- 整體改善分析報告
- 督導教育部進行全面改善。